

Security Monitoring Log - December 2024

Company A - Security Operations Center (SOC)

Document Control

Field	Details
Document Title	Security Monitoring Log - December 2024
Document ID	SOC-LOG-2024-12
Reporting Period	December 1, 2024 - December 31, 2024
Classification	CONFIDENTIAL - INTERNAL USE ONLY
Generated By	SOC Team (Splunk Enterprise Security SIEM)
SOC Manager	Fahad Al-Ghamdi (CISO)
Report Date	January 2, 2025
Distribution	CISO, IT Security Team, Executive Leadership, Audi
Next Report	January 31, 2025 (Monthly)

Table of Contents

- 1. Executive Summary 3
- 2. Security Monitoring Overview 5
 - 2.1 SOC Operations Statistics
 - 2.2 Technology Stack
- 3. Threat Landscape Analysis 7
 - 3.1 December 2024 Threat Trends
 - 3.2 Attack Vectors Observed
- 4. Security Incidents 10
 - 4.1 Incident Summary (15 Incidents)
 - 4.2 Critical & High Severity Incidents (Detailed)
 - 4.3 Medium & Low Severity Incidents
- 5. Alert Analysis 18
 - 5.1 Alert Statistics
 - 5.2 Top Alert Categories
 - 5.3 False Positive Analysis
- 6. Vulnerability Management 22
 - 6.1 Vulnerability Scan Results

- 6.2 Patch Management Status	
- 6.3 Critical Vulnerabilities Remediated	
7. User Behavior Analytics (UBA)	26
- 7.1 Anomalous User Activities	
- 7.2 Privileged User Monitoring	
8. Compliance Monitoring	29
- 8.1 PDPL Compliance Events	
- 8.2 NDMO Security Controls Monitoring	
9. Security KPIs & Metrics	31
10. Threat Intelligence Highlights	34
11. Recommendations & Action Items	36

1. Executive Summary

1.1 Month Overview

December 2024 was a HIGH ACTIVITY month for the Security Operations Center (SOC), with heightened threat activity leading up to the year-end holidays. The SOC processed 125.4 million security events, generated 45 security alerts, and created 15 security incidents for investigation.

Key Highlights:

- Zero critical incidents - All incidents successfully contained before data loss or system compromise
- Mean Time to Detect (MTTD): 12 minutes (↓ 3 min from Nov 2024) - IMPROVED
- Mean Time to Respond (MTTR): 35 minutes (↓ 8 min from Nov 2024) - IMPROVED
- False Positive Rate: 22% (↓ from 28% in Nov 2024) - Alert tuning efforts paying off
- Zero successful data breaches or patient data compromises

1.2 Top Security Findings

Rank	Finding	Severity	Count	Status
1	Phishing emails blocked (targeted campaigns)	HIGH	127 emails	■ BLOCKED
2	Brute force login attempts	MEDIUM	23 incidents	■ MITIGATED
3	Malware detections on endpoints	HIGH	8 detections	■ REMEDIATED
4	Unauthorized USB device attempts	LOW	12 attempts	■ BLOCKED
5	DLP policy violations (data exfiltration attempts)	MEDIUM	6 violations	■ BLOCKED

1.3 Critical Threats Mitigated

1. Advanced Phishing Campaign (Dec 8-10): Sophisticated phishing attack targeting 42 Company A employees with fake "Year-End Bonus" emails. 100% blocked by Proofpoint email gateway. Zero compromises.

2. Ransomware Attempt (Dec 18): CrowdStrike EDR detected and blocked LockBit 3.0 ransomware payload on a single endpoint (WS-FIN-12). Machine isolated and reimaged within 45 minutes. Zero data encrypted.
3. Privilege Escalation Attempt (Dec 22): Suspicious activity detected where a standard user account attempted to escalate privileges to domain admin using CVE-2024-38063 exploit. BLOCKED by Windows Defender and account suspended.

1.4 Security Posture Assessment

Overall Security Posture for December 2024: ■ STRONG

- Detection Capability: 98.2% (based on purple team testing)
- Incident Response Effectiveness: 100% (all incidents contained within SLA)
- Vulnerability Remediation Rate: 94.7% (critical/high vulns patched within 30 days)
- Security Awareness: 89% of employees passed monthly phishing simulation (↑ from 84% in Nov)

2. Security Monitoring Overview

2.1 SOC Operations Statistics

Monitoring Period: December 1-31, 2024 (31 days, 24/7 coverage)

Metric	December 2024	November 2024	Change
Total Security Events Collected	125,402,100	118,250,600	+6.0%
Events per Day (Average)	4,045,229	3,941,687	+2.6%
Security Alerts Generated	45	52	-13.5% ■
True Positive Alerts	35	37	-5.4%
False Positive Alerts	10	15	-33.3% ■
False Positive Rate	22%	28%	-6% ■
Security Incidents Created	15	18	-16.7%
Critical Incidents	0	0	No change
High Severity Incidents	3	5	-40% ■
Medium Severity Incidents	7	8	-12.5%
Low Severity Incidents	5	5	No change
Mean Time to Detect (MTTD)	12 min	15 min	-3 min ■
Mean Time to Respond (MTTR)	35 min	43 min	-8 min ■
Mean Time to Contain (MTTC)	68 min	78 min	-10 min ■

Interpretation:

- Alert volume decreased by 13.5% due to improved SIEM correlation rules and tuning

- False positive rate improved by 6 percentage points (from 28% to 22%)
- Detection and response times continue to improve month-over-month

2.2 Technology Stack

SOC Toolset:

Category	Tool	Purpose	Data Sources
SIEM	Splunk Enterprise Security	Centralized log management, correlation, alerting	450 logs, 12 systems
EDR	CrowdStrike Falcon	Endpoint detection & response	850 endpoints
Email Security	Proofpoint Email Protection	Phishing, malware, spam filtering	Office 365 mail flow
Firewall	Palo Alto Networks	Network traffic filtering, IDS/IPS	Perimeter + internal zones
DLP	Symantec DLP	Data exfiltration prevention	Endpoints, email, web
Vulnerability Scanner	Tenable Nessus	Vulnerability assessment	All servers & workstations
SOAR	Splunk SOAR	Incident response automation	All SOC tools
Threat Intelligence	Recorded Future	Threat intel feeds, IOC matching	Global threat data

Data Ingestion Sources (December 2024):

Data Source	Events/Day	Top Event Types
Windows Event Logs (850 endpoints)	2,850,000	Logon/logoff, file access, process creation
Linux/Unix Logs (95 servers)	420,000	SSH access, sudo commands, service restarts
Palo Alto Firewall Logs	650,000	Allowed/denied traffic, IDS alerts
CrowdStrike EDR Telemetry	1,200,000	Process execution, network connections, file chang
Office 365 Audit Logs	180,000	Email activity, file sharing, logins
Epic EHR Audit Logs	240,000	Patient record access, data modifications
Oracle Database Audit Logs	95,000	SQL queries, privileged user actions
AWS CloudTrail Logs	410,000	API calls, resource changes, IAM activity

3. Threat Landscape Analysis

3.1 December 2024 Threat Trends

Global Healthcare Threat Landscape:

Based on threat intelligence feeds (Recorded Future, Healthcare ISAC, SANS), the following trends were observed in December 2024:

1. Ransomware Targeting Healthcare (CRITICAL):
 - LockBit 3.0 and ALPHV/BlackCat ransomware groups intensified attacks on healthcare providers
 - 12 healthcare organizations globally hit by ransomware in December (4 in MENA region)
 - Average ransom demand: \$2.5 million USD (~SAR 9.4 million)
2. Year-End Phishing Campaigns (HIGH):
 - Significant increase in "bonus," "holiday," and "tax document" themed phishing emails
 - Attackers leveraging AI-generated phishing content (harder to detect)
 - Company A saw 127 targeted phishing emails (all blocked)
3. Vulnerability Exploitation (HIGH):
 - Active exploitation of Microsoft Windows CVE-2024-38063 (privilege escalation)
 - Apache Log4j still being exploited in legacy systems (CVE-2021-44228)
 - Epic EHR vulnerability disclosed (CVE-2024-12345) - Company A patched Dec 20
4. Insider Threats (MEDIUM):
 - Healthcare industry seeing increase in malicious insiders selling patient data
 - Average price for 1,000 patient records on dark web: \$150 USD

3.2 Attack Vectors Observed at Company A

Attack Vector Distribution (December 2024):

Attack Vector	Attempts	Successful	Success Rate	Mitigation
Phishing emails	127	0	0%	Proofpoint email filtering
Brute force (SSH/RDP/Web)	23	0	0%	Account lockout policies, MFA
Malware (endpoints)	8	0	0%	CrowdStrike EDR
DLP violations	6	0	0%	Symantec DLP blocking
Unauthorized USB devices	12	0	0%	Device control policies
Vulnerability exploitation	2	0	0%	Patch management, WAF
Privilege escalation	1	0	0%	EDR behavioral detection
Social engineering	3	0	0%	User reporting + investigation
TOTAL	182	0	0%	■ 100% BLOCKED

Key Insight: Zero successful attacks in December 2024. All 182 attack attempts were detected and blocked by security controls.

4. Security Incidents

4.1 Incident Summary (15 Incidents)

Inc ID	Date	Severity	Type	Description	Status
INC-SEC-992	Dec 5	LOW	Brute Force	Failed login attempts (10x) to HR portal	CLOSED
INC-SEC-993	Dec 8	HIGH	Phishing	Targeted phishing campaign (42 employees)	CLOSED
INC-SEC-994	Dec 10	MEDIUM	Policy Violation	Unauthorized software installed	CLOSED
INC-SEC-995	Dec 12	MEDIUM	Malware	Trojan.Win32 detected on workstation	CLOSED
INC-SEC-996	Dec 14	LOW	Brute Force	SSH brute force on test server	CLOSED
INC-SEC-997	Dec 16	MEDIUM	Data Exfiltration Attempt	Large file upload to Dropbox	CLOSED
INC-SEC-998	Dec 18	HIGH	Ransomware	LockBit 3.0 payload detected on server	CLOSED
INC-SEC-999	Dec 19	LOW	Unauthorized Access	User accessed file outside of scope	CLOSED
INC-SEC-1000	Dec 20	MEDIUM	DLP Violation	Attempt to email patient data	CLOSED
INC-SEC-1001	Dec 21	LOW	USB Device	Unauthorized USB device plugged	CLOSED
INC-SEC-1002	Dec 22	HIGH	Privilege Escalation	CVE-2024-38063 exploit attempt	CLOSED
INC-SEC-1003	Dec 24	MEDIUM	Suspicious Login	Login from unfamiliar geo location	CLOSED
INC-SEC-1004	Dec 26	MEDIUM	Anomalous Query	Privileged user ran unusual query	CLOSED
INC-SEC-1005	Dec 28	LOW	DLP Violation	Encrypted zip file upload blocked	CLOSED
INC-SEC-1006	Dec 30	MEDIUM	Brute Force	Multiple failed logins to patient portal	CLOSED

Total Incidents: 15

- High Severity: 3 (20%)
- Medium Severity: 7 (46.7%)
- Low Severity: 5 (33.3%)
- Critical Severity: 0 (0%)

4.2 Critical & High Severity Incidents (Detailed)

INC-SEC-993: Targeted Phishing Campaign (HIGH)

Field	Details
Incident ID	INC-SEC-993
Date & Time	December 8, 2024 @ 09:15 AM - December 10, 2024 @ 05:00 PM
Severity	HIGH
Category	Phishing / Social Engineering
Detection Method	Proofpoint email security gateway + user reports
Affected Systems	Email (Office 365)
Affected Users	42 employees targeted; 0 compromised

Incident Description:

Between December 8-10, Company A employees received a sophisticated phishing email campaign with the subject line: "■ Year-End Performance Bonus - Action Required". The emails appeared to come from the CFO (spoofed email address cfo@companya-bonus.com) and contained a link to a fake "bonus claim" website designed to steal Office 365 credentials.

Attack Details:

- Sender: `cfo@companya-bonus.com` (spoofed; legitimate domain: `companya.gov.sa`)
- Subject: "■ Year-End Performance Bonus - Action Required"
- Body: Professional-looking email with Company A logo, urgent language ("claim by Dec 10 or forfeit bonus")
- Malicious Link: `https://companya-portal[.]xyz/bonus-claim` (fake credential harvesting site)
- Targets: 42 employees in Finance, HR, and IT departments (likely scraped from LinkedIn)

Response Actions Taken:

1. 09:20 AM (Dec 8): Proofpoint email gateway detected phishing signatures and auto-quarantined all 42 emails before delivery
2. 09:45 AM: SOC analyst reviewed quarantined emails, confirmed phishing campaign
3. 10:00 AM: Alert sent to all 42 targeted employees via email and SMS: "Phishing email blocked; do not click any links"
4. 11:30 AM: DNS sinkhole configured to block access to companya-portal[.]xyz domain
5. Dec 10, 2:30 PM: Campaign ended (no further emails detected)

Impact Assessment:

- Credentials Stolen: 0 (all emails blocked before delivery)
- Systems Compromised: 0
- Data Loss: None
- Estimated Financial Impact: SAR 0 (attack prevented)

Lessons Learned:

- Proofpoint email filtering 100% effective in blocking this campaign
- User awareness training effective: 3 employees who saw quarantined emails immediately reported to SOC (good security culture)
- Recommend: Add `companya-bonus.com` and similar lookalike domains to DNS blacklist

Status: ■ CLOSED (Dec 10, 2024)

INC-SEC-998: LockBit 3.0 Ransomware Attempt (HIGH)

Field	Details
Incident ID	INC-SEC-998
Date & Time	December 18, 2024 @ 02:48 PM
Severity	HIGH
Category	Malware / Ransomware

Detection Method	CrowdStrike Falcon EDR (behavioral detection)
Affected Systems	1 endpoint: WS-FIN-12 (Finance Department workstat
Affected Users	Noura Al-Shahrani (Finance Analyst)

Incident Description:

CrowdStrike Falcon EDR detected and automatically blocked a LockBit 3.0 ransomware payload that attempted to execute on a Finance Department workstation. The malware was delivered via a macro-enabled Excel spreadsheet disguised as an "Invoice.xlsm" file.

Attack Chain:

1. Initial Access: User noura.s received email with attachment Invoice_Dec2024.xlsm from external sender (spoofed vendor email)
2. Execution: User opened the Excel file and enabled macros (against policy)
3. Malware Download: Macro script downloaded LockBit 3.0 ransomware payload from external C2 server (185.220.101.42)
4. Detection & Block: CrowdStrike detected malicious behavior (file encryption attempt) and killed the process within 8 seconds
5. Isolation: Workstation automatically isolated from network by CrowdStrike

Response Actions Taken:

Time	Action	Owner
02:48 PM	CrowdStrike auto-blocks ransomware process	Automated (EDR)
02:50 PM	SOC alert received; analyst begins investigation	SOC Analyst (Khalid M.)
02:55 PM	Workstation isolated from network (CrowdStrike)	Automated
03:10 PM	User noura.s notified; instructed to power off mac	SOC Analyst
03:30 PM	Forensic analysis: confirmed LockBit 3.0, zero fil	Incident Response Team
04:00 PM	Workstation reimaged with clean OS image	IT Support
05:15 PM	User files restored from OneDrive backup; workstat	IT Support

Impact Assessment:

- Files Encrypted: 0 (ransomware blocked before encryption)
- Downtime: 2.5 hours (for reimaging and restoration)
- Data Loss: None (all files recovered from OneDrive)
- Estimated Financial Impact: SAR 1,200 (staff time for incident response + reimaging)

Root Cause:

- User violated security policy by enabling macros in an unsolicited email attachment
- Email attachment bypassed Proofpoint (sent from previously legitimate but compromised vendor email address)

Remediation Actions:

1. Immediate: Macro execution disabled via Group Policy for all Finance Department users (Dec 18, 6:00 PM)

2. Short-term: Security awareness training scheduled for all Finance users (Dec 20)
3. Long-term: Implement Office 365 ATP Safe Documents (blocks macro execution in Protected View) - Target: Jan 15, 2025

Lessons Learned:

- CrowdStrike EDR performed exceptionally well: detected and blocked ransomware within 8 seconds
- Users continue to enable macros despite training (11th policy violation in 2024)
- Need to enforce technical controls (disable macros via GPO) rather than rely on user compliance

Status: ■ CLOSED (Dec 18, 2024)

INC-SEC-1002: Privilege Escalation Exploit Attempt (HIGH)

Field	Details
Incident ID	INC-SEC-1002
Date & Time	December 22, 2024 @ 11:22 AM
Severity	HIGH
Category	Privilege Escalation / Exploitation
Detection Method	Windows Defender + CrowdStrike EDR
Affected Systems	1 endpoint: WS-IT-28 (IT Department workstation)
Affected Users	Standard user account contractor.temp (temporary c

Incident Description:

Windows Defender and CrowdStrike detected an attempt to exploit CVE-2024-38063 (Windows TCP/IP privilege escalation vulnerability) on an IT contractor's workstation. The exploit would have granted the contractor SYSTEM-level privileges on the machine and potentially allowed lateral movement to other systems.

Attack Details:

- Vulnerability: CVE-2024-38063 (CVSS 9.8 - Critical) - Windows TCP/IP Remote Code Execution
- Exploit Tool: Publicly available exploit code from GitHub (PoC released Dec 15, 2024)
- Attacker: Likely the contractor (`contractor.temp`) testing security controls (still under investigation)
- Intent: Unknown (possible malicious insider, or contractor testing company defenses)

Response Actions Taken:

Time	Action	Owner
11:22 AM	Windows Defender blocks exploit execution	Automated (Defender)
11:23 AM	CrowdStrike alert: privilege escalation attempt de	Automated (EDR)
11:25 AM	SOC analyst receives alert and begins investigatio	SOC Analyst
11:30 AM	User account contractor.temp suspended (Active Dir	SOC Analyst

11:35 AM	Workstation isolated from network	SOC Analyst
12:00 PM	Contractor questioned by IT Security Manager	CISO
12:45 PM	Contractor admits to "testing security" without au	CISO
01:30 PM	Contractor escorted off premises; access revoked	HR + Security
Dec 23	Workstation forensically analyzed; no further mali	Incident Response

Impact Assessment:

- Privilege Escalation Successful: NO (blocked by Windows Defender)
- Systems Compromised: 0
- Data Accessed: None
- Estimated Financial Impact: SAR 4,500 (investigation time + contractor termination costs)

Root Cause:

- Temporary contractor violated Acceptable Use Policy by downloading and executing exploit code
- Contractor claimed they were "testing Company A's security posture" without authorization
- Lack of background check for short-term contractors (hired through agency)

Remediation Actions:

1. Immediate: All temporary contractor accounts reviewed for suspicious activity (Dec 22)
2. Short-term: Update contractor onboarding process to include security background checks (Target: Jan 10, 2025)
3. Long-term: Implement privileged access management (PAM) for all contractor accounts (Target: Q1 2025)

Lessons Learned:

- Defense-in-depth worked: vulnerability was unpatched, but exploit was blocked by endpoint security
- Need stronger vetting process for contractors (even short-term engagements)
- Insider threat detection is critical (user behavior analytics flagged unusual activity)

Status: ■ CLOSED (Dec 23, 2024) - Contractor terminated

4.3 Medium & Low Severity Incidents (Summary)

Medium Severity Incidents (7 total):

Inc ID	Date	Type	Summary	Outcome
INC-SEC-994	Dec 10	Policy Violation	User installed unapproved software (Team Viewer)	Software uninstalled; warning issued
INC-SEC-995	Dec 12	Malware	Trojan.Win32 detected on Finance workstation	Workstation moved; machine scanned
INC-SEC-997	Dec 16	Data Exfiltration	User attempted to upload 2.4 GB PDF to Dropbox	Upload blocked; user counseled
INC-SEC-1000	Dec 20	DLP Violation	User attempted to email patient data to personal email	Email blocked; DLP violation reported to DFO
INC-SEC-1003	Dec 24	Suspicious Login	Login from unfamiliar location (Turkey VPN)	User confirmed legitimate (traveling); MFA verified
INC-SEC-1004	Dec 26	Anomalous Query	DBA ran unusual SELECT query on patient table	Query prevented; determined to be legitimate

INC-SEC-1006	Dec 30	Brute Force	18 failed login attempts to patient portal	IP address blocked; no accounts compromised
--------------	--------	-------------	--	---

Low Severity Incidents (5 total):

Inc ID	Date	Type	Summary	Outcome
INC-SEC-992	Dec 5	Brute Force	10 failed login attempts (user forgot password)	Account locked; password reset
INC-SEC-996	Dec 14	Brute Force	SSH brute force on decommissioned server	Server taken offline
INC-SEC-999	Dec 19	After-Hours Access	User accessed file at 2:00 AM (working late)	Accessed legitimately; no violation
INC-SEC-1001	Dec 21	USB Device	Unauthorized USB drive plugged in	Device blocked; user warned
INC-SEC-1005	Dec 28	DLP Violation	User tried to upload encrypted zip file	File blocked; user provided alternative method

5. Alert Analysis

5.1 Alert Statistics

Total Alerts Generated: 45 (December 2024)

Alert Disposition	Count	Percentage
True Positive (Escalated to Incident)	15	33.3%
True Positive (Informational, no incident)	20	44.4%
False Positive	10	22.2%
TOTAL	45	100%

Alert Severity Breakdown:

Severity	Alerts	True Positives	False Positives
CRITICAL	0	0	0
HIGH	8	7	1
MEDIUM	22	18	4
LOW	15	10	5
TOTAL	45	35	10

5.2 Top Alert Categories

Rank	Alert Category	Count	% of Total	Top Sub-Types
------	----------------	-------	------------	---------------

1	Brute Force / Failed Logins	12	26.7%	RDP, SSH, Web logins
2	Malware Detection	8	17.8%	Trojans, adware, PUPs
3	DLP Violations	7	15.6%	Email, file upload, USB
4	Phishing Emails	6	13.3%	Credential harvesting, malware delivery
5	Suspicious Network Traffic	5	11.1%	C2 beaconing, unusual ports
6	Unauthorized Access	4	8.9%	After-hours access, unusual geolocation
7	Policy Violations	3	6.7%	Software installation, USB devices

5.3 False Positive Analysis

Total False Positives: 10 (22.2% of alerts)

Root Causes of False Positives:

Root Cause	Count	Example	Resolution
Overly sensitive threshold	4	Alert triggered for 3 failed logins (threshold was 3)	Threshold increased to 5 failed logins
Legitimate business activity	3	DLP flagged legitimate large file transfer	Whitelist added for specific user/folder
Signature mismatch	2	Malware alert on legitimate software update	Signature updated in EDR
User behavior anomaly	1	Alert for user logging in from home (WFH)	User baseline updated

False Positive Reduction Efforts:

- December 2024: 10 false positives (22% FP rate)
- November 2024: 15 false positives (28% FP rate)
- Improvement: 33% reduction in false positives

Actions Taken:

- Tuned 8 SIEM correlation rules to reduce noise
- Updated CrowdStrike custom IOAs (Indicators of Attack)
- Added 12 whitelists for known-good activities

6. Vulnerability Management

6.1 Vulnerability Scan Results

Scan Date: December 15, 2024

Scanner: Tenable Nessus Professional

Scope: All Company A IT assets (servers, workstations, network devices)

Metric	Value
Total Hosts Scanned	450
Total Vulnerabilities Detected	1,247
CRITICAL Vulnerabilities	0
HIGH Vulnerabilities	2
MEDIUM Vulnerabilities	45
LOW Vulnerabilities	1,200

Critical Vulnerabilities: 0 (all critical vulns remediated within 7-day SLA)

High Vulnerabilities (2 remaining):

CVE ID	Vulnerability	Affected Systems	Risk Score	Remediation Plan	Due Date
CVE-2024-45678	Apache Tomcat RCE	1 server (APP-SRV-08)	8.8 (HIGH)	Patch scheduled for Dec 22	Dec 22
CVE-2024-56789	Oracle WebLogic XXE	1 server (WEB-SRV-12)	8.1 (HIGH)	Vendor patch not yet available	Jan 15, 2025

6.2 Patch Management Status

Patch Compliance (December 2024):

Operating System	Hosts	Fully Patched	Compliance %
Windows Server (2019/2022)	85	82	96.5%
Windows 10/11 (endpoints)	850	842	99.1%
Red Hat Enterprise Linux	45	43	95.6%
Ubuntu Server	28	28	100%
Network Devices (Cisco, Palo Alto)	22	21	95.5%
TOTAL	1,030	1,016	98.6%

Patch SLA Compliance:

Severity	SLA	Patches Due in Dec	Patched On Time	Compliance
CRITICAL	7 days	0	0	N/A
HIGH	30 days	12	11	91.7%
MEDIUM	90 days	28	27	96.4%
LOW	180 days	45	45	100%

Overdue Patches:

- 1 HIGH patch overdue (CVE-2024-56789 - Oracle WebLogic) - vendor patch not available yet; mitigation in place (WAF rule)

6.3 Critical Vulnerabilities Remediated in December

CVE ID	Vulnerability	Affected	Remediated Date	Mitigation
CVE-2024-38063	Windows TCP/IP RCE	850 Windows endpoints	Dec 10, 2024	Microsoft patch (KB5048652)
CVE-2024-12345	Epic EHR authentication bypass	Epic production servers	Dec 20, 2024	Epic vendor patch (v2024.12)
CVE-2024-98765	Palo Alto PAN-OS DoS	8 firewalls	Dec 8, 2024	Palo Alto update (PAN-OS 11.2.3)

7. User Behavior Analytics (UBA)

7.1 Anomalous User Activities Detected

Splunk UBA Risk Scores (Top 10 Users):

Rank	User	Risk Score	Anomalies Detected	Investigation Result
1	contractor.temp	85 (HIGH)	Privilege escalation attempt	Malicious - Contractor terminated (INC-SEC-2024-001)
2	noura.s	72 (MEDIUM)	Enabled macros; downloaded malware	User error - Retrained
3	ahmed.h	45 (LOW)	Login from Turkey (VPN while traveling)	Legitimate - User confirmed
4	fatima.m	38 (LOW)	Large file download (5 GB dataset)	Legitimate - Approved data analytics project
5	khalid.a	35 (LOW)	8 failed login attempts (forgot password)	User error - Password reset
6	sara.k	32 (LOW)	After-hours access (worked until 11 PM)	Legitimate - Project deadline
7	mohammed.r	28 (LOW)	Unusual SQL query pattern	Legitimate - Database troubleshooting
8	layla.z	25 (LOW)	Access to 150 patient records in 10 min	Legitimate - Medical audit
9	abdullah.s	22 (LOW)	USB device plugged in	Policy violation - Warning issued
10	nora.t	20 (LOW)	Attempted Dropbox upload	DLP blocked - User counseled

UBA Summary:

- 1 true malicious insider detected (contractor)
- 9 low-risk anomalies (all investigated and resolved)
- No unauthorized patient data access detected

7.2 Privileged User Monitoring

Privileged Accounts Monitored: 24 (domain admins, database admins, system admins)

Privileged User Activity (December 2024):

Activity	Count	Anomalies	Incidents
Domain admin logins	142	0	0
Database admin queries	1,850	1 (unusual SELECT)	0 (legitimate)
System admin remote access (SSH/RDP)	420	0	0
Cloud admin (AWS/Azure) API calls	3,200	0	0
Privileged file access	2,100	0	0

- Privileged Access Compliance:
- 100% of privileged sessions logged and recorded
 - 0 policy violations by privileged users
 - 0 unauthorized privilege escalations

8. Compliance Monitoring

8.1 PDPL Compliance Events

PDPL-Related Security Events (December 2024):

Event Type	Count	Compliance Status
Patient data access (authorized)	2.4 million	■ COMPLIANT
Patient data modifications	180,000	■ COMPLIANT
Data subject access requests (DSAR)	42	■ COMPLIANT (all fulfilled within 30 days)
Consent withdrawals	18	■ COMPLIANT (data deleted within 7 days)
PDPL violations detected	1	■ VIOLATION (INC-SEC-1000)

- PDPL Violation Details:
- Incident: INC-SEC-1000 (Dec 20) - Employee attempted to email patient data to personal Gmail account
 - Root Cause: User error (employee working from home, wanted to access data on personal device)
 - Mitigation: DLP blocked email before sending; no data exfiltrated
 - Corrective Action: User retrained on PDPL requirements; formal warning issued
 - DPO Notification: Data Protection Officer notified on Dec 20; incident logged

8.2 NDMO Security Controls Monitoring

NDMO Domain 5 (Data Security) - Continuous Monitoring:

NDMO Control	Monitoring Method	Compliance Status
5.1.1 - Data encryption at rest	Daily scan of all databases	■ 100% compliant
5.1.2 - Data encryption in transit	TLS/SSL certificate monitoring	■ 100% compliant
5.2.1 - Access control enforcement	SIEM monitoring of access logs	■ 99.8% compliant
5.3.1 - Security event logging	Splunk log ingestion monitoring	■ 100% compliant
5.4.1 - Incident response capability	MTTR tracking	■ MTTR = 35 min (target: < 60 min)
5.5.1 - Vulnerability management	Patch compliance tracking	■ 98.6% patched

Overall NDMO Security Posture: ■ COMPLIANT (99.5% across all Domain 5 controls)

9. Security KPIs & Metrics

9.1 SOC Performance Metrics

KPI	Target	December 2024	November 2024	Trend
Mean Time to Detect (MTTD)	< 15 min	12 min ■	15 min	↓ IMPROVED
Mean Time to Respond (MTTR)	< 60 min	35 min ■	43 min	↓ IMPROVED
Mean Time to Contain (MTTC)	< 120 min	68 min ■	78 min	↓ IMPROVED
False Positive Rate	< 25%	22% ■	28%	↓ IMPROVED
Alert Closure Rate (within 24h)	> 95%	100% ■	98%	↑ IMPROVED
Incident Containment Rate	100%	100% ■	100%	■ MAINTAINED
Zero-Day Detection Coverage	> 95%	98.2% ■	97.5%	↑ IMPROVED

9.2 Security Control Effectiveness

Security Control	Effectiveness (Dec 2024)	Attacks Blocked
Email Security (Proofpoint)	99.2%	127 phishing emails blocked
Endpoint Protection (CrowdStrike)	100%	8 malware infections blocked
Data Loss Prevention (Symantec DLP)	100%	6 data exfiltration attempts blocked
Firewall/IPS (Palo Alto)	99.8%	1,240 malicious IPs blocked
MFA (Microsoft Authenticator)	100%	0 account takeovers despite 23 brute force attempt
Patch Management	98.6%	3 critical CVEs patched within SLA

9.3 Security Awareness Metrics

Metric	December 2024	November 2024	Target
Phishing Simulation Pass Rate	89%	84%	> 85%
Security Training Completion	94%	92%	> 90%
User-Reported Phishing Emails	12	8	> 10
Policy Violations	6	9	< 10

Key Insight: Security awareness improving month-over-month. Users are more vigilant and reporting suspicious emails.

10. Threat Intelligence Highlights

10.1 Global Threat Intelligence (December 2024)

Top Threats Relevant to Healthcare (Source: Recorded Future, Healthcare ISAC):

1. LockBit 3.0 Ransomware:
 - 12 healthcare organizations hit globally in December
 - Exploiting unpatched Citrix NetScaler (CVE-2023-4966) and FortiOS (CVE-2023-27997)
 - Company A Status: Mitigated (no Citrix/Fortinet in use; CrowdStrike blocked 1 attempt)
2. Epic EHR Vulnerability (CVE-2024-12345):
 - Authentication bypass vulnerability disclosed Dec 18, 2024
 - Allows unauthenticated access to patient records API
 - Company A Status: Patched on Dec 20 (within 48-hour SLA)
3. PhaaS (Phishing-as-a-Service) Platforms:
 - Increase in AI-generated phishing emails (harder to detect)
 - Healthcare providers targeted with "insurance claim" and "bonus" themed campaigns
 - Company A Status: All phishing emails blocked (127 in December)
4. Russian APT28 (Fancy Bear) Targeting Healthcare:
 - APT28 targeting European and Middle Eastern healthcare entities
 - Suspected nation-state espionage (stealing vaccine research, patient data)
 - Company A Status: Monitoring (no indicators of compromise detected)

10.2 Indicators of Compromise (IOCs) Monitored

IOCs Added to Block List (December 2024):

IOC Type	Count	Source
Malicious IP addresses	1,240	Recorded Future, Threat Intel feeds

Malicious domains	450	Healthcare ISAC, SANS ISC
Malware hashes (SHA256)	2,100	CrowdStrike Threat Graph
Phishing URLs	127	Proofpoint TAP

IOC Matches (Blocked Attacks):

- 18 connections to known C2 servers blocked by firewall
- 12 malware downloads blocked by web proxy
- 127 phishing URLs quarantined by email gateway

11. Recommendations & Action Items

11.1 Immediate Actions (Next 30 Days)

Priority	Recommendation	Owner	Due Date	Budget
P1	Disable macros via Group Policy for all users (not	IT Security	Jan 15, 2025	No cost
P2	Implement Office 365 ATP Safe Links	IT Security	Jan 20, 2025	SAR 45,000/year
P3	Add background checks for all contractors (even sh	HR/Sec (even sh	Jan 10, 2025	SAR 8,000
P4	Deploy Privileged Access Management (PAM) solution	IT Security	Feb 28, 2025	SAR 380,000

11.2 Strategic Initiatives (Next 90-180 Days)

- Enhanced Insider Threat Detection:
 - Deploy Varonis DataAdvantage for privileged user monitoring
 - Budget: SAR 420,000
 - Timeline: Q1 2025
- Security Awareness Program Expansion:
 - Increase phishing simulation frequency to weekly (currently monthly)
 - Add role-based training (Finance, HR, IT, Clinical)
 - Budget: SAR 85,000
 - Timeline: Q1 2025
- SOAR Automation Expansion:
 - Automate 80% of Tier 1 SOC tasks (currently 40%)
 - Reduce MTTR to < 20 minutes (currently 35 min)
 - Budget: SAR 220,000
 - Timeline: Q2 2025

11.3 Lessons Learned (December 2024)

1. Defense-in-depth is working: Multiple incidents (ransomware, privilege escalation) were blocked despite vulnerabilities existing
2. Users remain the weakest link: 6 policy violations in December (macro execution, unauthorized software, USB devices)
3. Contractor vetting needs improvement: Insider threat from contractor highlights gap in background check process
4. Alert tuning paying off: False positive rate decreased from 28% (Nov) to 22% (Dec)

END OF SECURITY MONITORING LOG

Report Prepared By: Fahad Al-Ghamdi, CISO

SOC Team: Khalid M. (Lead Analyst), Sara K. (Analyst), Mohammed R. (Analyst)

Next Report: January 31, 2025

This document is classified as CONFIDENTIAL. Unauthorized disclosure may result in security compromise.

Company A - Protecting Patient Data Through Vigilant Security Monitoring